

SL1PCONNECT SAS

Plan d'action SOC - Integration ISO 27001:2022

Mapping ISO 27001 - KPIs SOC - Quick Wins - Feuille de route

Wazuh SOC - TheHive - Stormshield - Conformite RGPD/HDS

Date	Juin 2026
Validé par	Denis THREADNEEDLE (DSI) - Victor SLIPMAN (PDG)
Périmètre	Infrastructure OVH + Siège Nice
Groupe	75 : Hugo, Louis, Envel, Cyran

1. Mapping ISO 27001:2022 - Contrôles couverts par le SOC

Identification des contrôles ISO 27001:2022 directement couverts ou partiellement couverts par le SOC POC, en partant de la situation initiale (0 contrôle formalisé).

Contrôle	Libellé ISO 27001:2022	Statut	Livrable SOC / Preuve
A.5.24	Planification et préparation de la gestion des incidents	Couvert	Processus P1-P4, RACI, SLA définis
A.5.25	Evaluation et décision sur les événements de sécurité	Couvert	Classification et triage automatisé TheHive
A.5.26	Réponse aux incidents de sécurité	Couvert	5 playbooks Kill Chain (PB-01 a PB-05)
A.5.27	Retour d'expérience des incidents	Couvert	Template REX obligatoire P1/P2, registre
A.8.15	Journalisation	Couvert	Agents Wazuh Linux / Windows / Docker / Stormshield
A.8.16	Surveillance des activités	Couvert	8 règles de corrélation actives + dashboard Kibana
A.5.34	Vie privée et protection des données personnelles	Partiel	Procédure CNIL art.33 72h - DPA OVH a signer (QW-06)
A.5.30	Préparation TIC pour la continuité (PRA)	Partiel	PB-05 Ransomware - PRA complet phase 2
A.8.8	Gestion des vulnérabilités techniques	Partiel	Use Cases SOC-UC-07 a UC-11 - patch management phase 2
A.5.15	Gestion des accès et des identités	Partiel	SOC-UC-03 MFA Fatigue - MFA complet phase 2
A.8.25	Sécurisation du cycle de développement	Gap	Action De SecOps requise - Trivy CI/CD phase 2

Situation initiale : 0 contrôle couvert (absence SIEM, pas de processus incidents formalise, RSSI vacant). Après déploiement du SOC POC : 6 contrôles totalement couverts + 4 partiellement. La SOA v1 est livrée en M+3.

2. KPIs de performance du SOC

Indicateurs de performance opérationnels et de conformité ISO 27001 mesures via la stack Wazuh / TheHive / Kibana.

2.1 KPIs opérationnels

Indicateur	Cible	Fréquence	Mesure via
MTTD - Temps moyen de détection	< 15 min (P1/P2)	Temps réel	Dashboard Kibana
MTTR - Temps moyen de réponse	< 1h P1 / < 4h P2	Par incident	TheHive SLA tracker
Taux SLA respectés	> 90%	Mensuel	Rapport mensuel TheHive
Taux de faux positifs SIEM	< 20%	Hebdomadaire	Wazuh / Kibana
REX produits dans les délais	> 95%	Mensuel	Registre REX

2.2 KPIs de conformité ISO 27001

KPI Conformité	Cible a 12 mois	Contrôle ISO lie
Contrôles ISO 27001 couverts par le SOC	0/93 => 25+/93	A.5.24 a A.5.27 / A.8.15 a A.8.16
Incidents DSCP notifiés CNIL dans les 72h	100% (art.33 RGPD)	A.5.34
Playbooks révisés après chaque REX P1/P2	100% des incidents	A.5.27
Incidents P1 sans REX documenté	0 toléré	A.5.26 / A.5.27
Assets critiques couverts par le SIEM	100% actifs critiques	A.8.15
Use cases valides par demo live	11/11	A.8.16

3. Plan d'action priorise - Quick Wins

Actions à impact immédiat sur la conformité ISO 27001, réalisables avec la stack existante (Wazuh, TheHive, Stormshield), sans budget supplémentaire, dans un délai inférieur ou égal à J+7.

Ref.	Action	Effort	Contrôle ISO	Jalon / Coût
QW-01	Changer credentials Grafana (admin/admin) + restreindre port 9090 au LAN uniquement	0,5j	A.5.15	J+2 - 0 EUR
QW-02	Activer alerting Wazuh Event ID 1102 (log cleared Windows AD)	2h	A.8.16	J+1 - 0 EUR
QW-03	Deployer regles P1 : SQLI-BRIEF-001, BRUTE-ADMIN-001, EXFIL-PGSQL-001	1j	A.8.15 / A.8.16	J+5 - 0 EUR
QW-04	Formaliser RACI + classification P1-P4 dans TheHive	0,5j	A.5.24 / A.5.25	J+3 - 0 EUR
QW-05	Configurer templates tickets TheHive (PB-01 a PB-05)	0,5j	A.5.26	J+5 - 0 EUR
QW-06	Signer DPA OVH - formaliser chaîne responsabilité HDS données sante	1j	A.5.34	J+7 - 0 EUR
QW-07	Activer FIM Syscheck Wazuh sur répertoires web Nginx (Cartman/Stam/Kyle/Kenny)	2h	A.8.16	J+3 - 0 EUR
QW-08	Creer comptes SSH individuels par admin, supprimer clés partagées	1j	A.5.15 / A.5.17	J+7 - 0 EUR
QW-09	Documenter REX incident juillet 2024 - analyse RGPD art.33 non notifie	0,5j	A.5.27 / A.5.34	J+3 - 0 EUR
QW-10	Intégrer logs Stormshield Nice + OVH dans Wazuh (syslog forwarding)	1j	A.8.15 / A.8.20	J+7 - 0 EUR

Budget total Quick Wins : 0 EUR - Toutes les actions s'appuient sur la stack déjà déployée. L'enveloppe de 15 000 EUR est intégralement préservée pour les phases suivantes.

4. Feuille de route - Jalons ISO 27001 (12-24 mois)

Plan d'action détaillé et priorisé avec jalons de remédiation (n+1) et objectif certification (n+2). Budget dimensionné sur l'enveloppe disponible de 15 000 EUR pour les phases 1 à 3.

Phase 1 - SOC opérationnel + Quick Wins Mois 0-3 Budget : < 500 EUR		
Action	Contrôle ISO 27001	Jalon
Wazuh multi-sources opérationnel (OVH DMZ + AD Nice + Docker + Stormshield)	A.8.15 / A.8.16	M+1
8 use cases actifs + démo live des 3 scénarios d'attaque	A.8.16	M+2
Processus incidents formalise (RACI, SLA, playbooks PB-01 a PB-05)	A.5.24 a A.5.27	M+1
TheHive opérationnel + ticketing automatisé depuis Wazuh	A.5.25 / A.5.26	M+2
DPA OVH signe + chaine HDS formalisée	A.5.34	M+1
SOA v1 livrée (Déclaration d'Applicabilité)	ISO 27001 §6.1.3	M+3

Phase 2 - Consolidation et couverture ISO Mois 3-6 Budget : env. 5 500 EUR		
Action	Contrôle ISO 27001	Jalon
WAF ModSecurity devant BRIEF :8081 et BOXER :8080 (env. 500 EUR)	A.8.25	M+4
MFA obligatoire tous comptes admin - BRIEF, Grafana, AD (env. 500 EUR)	A.5.15 / A.5.17	M+4
Scan images Docker Trivy integre CI/CD GitHub Actions (env. 1 000 EUR)	A.8.8 / A.8.25	M+5
Migration secrets Docker vers HashiCorp Vault (env. 2 000 EUR)	A.8.9	M+6
PSSI v2.0 validée + charte informatique signée (env. 1 500 EUR)	ISO 27001 §5.2 / §7.2	M+5
PRA formalise et testé sur base PB-05 (0 EUR)	A.5.30	M+6

Phase 3 - Pre-audit ISO 27001 et HDS Mois 6-12 Budget : env. 7 000 EUR		
Action	Contrôle ISO 27001	Jalon
Analyse de risques ISO 27005 / EBIOS RM périmètre complet	ISO 27001 §6.1.2	M+8
SOA v2 finalisée avec plan de traitement des risques	ISO 27001 §6.1.3	M+9
Audit blanc ISO 27001 par organisme externe (env. 3 000 EUR)	ISO 27001 §9.2	M+10
Démarche HDS - audit préparatoire OVH (env. 2 000 EUR)	Exigence HDS	M+10
Tests d'intrusion annuels OVH + applications web (env. 2 000 EUR)	A.8.8	M+11
Tableau de bord SMSI direction operationnel	ISO 27001 §9.1	M+12

Phase 4 - Certification et evolution SOC Mois 12+ Budget : env. 35 000 EUR		
Action	Contrôle ISO 27001	Jalon
Audit de certification ISO 27001 par organisme certifié (env. 8 000 EUR)	ISO 27001 §9.2	M+14
Certification HDS obtenue - condition levée de fonds Série B débloquée	Exigence HDS / CNIL	M+15
Migration postes Windows XP / Win7 (env. 15 000 EUR)	A.8.8	M+18
Evaluation SOC MDR externalise 24/7 santé/IoT (env. 12 000 EUR/an)	Evolution SOC	M+18

Synthese budgetaire

Phase	Période	Budget	Source
Phase 1 - SOC POC + Quick Wins	M0-M3	< 500 EUR	Budget IT courant

Phase 2 - Consolidation ISO	M3-M6	env. 5 500 EUR	Budget remédiation alloue
Phase 3 - Pre-audit + HDS	M6-M12	env. 7 000 EUR	Budget remédiation alloue
TOTAL Phase 1-3	M0-M12	env. 13 000 EUR	< 15 000 EUR alloués
Phase 4 - Certification + MDR	M12+	env. 35 000 EUR	Levée de fonds Serie B

-- FIN DU DOCUMENT --